

Análisis de seguridad de una arquitectura de red corporativa híbrida (on-premise + nube)

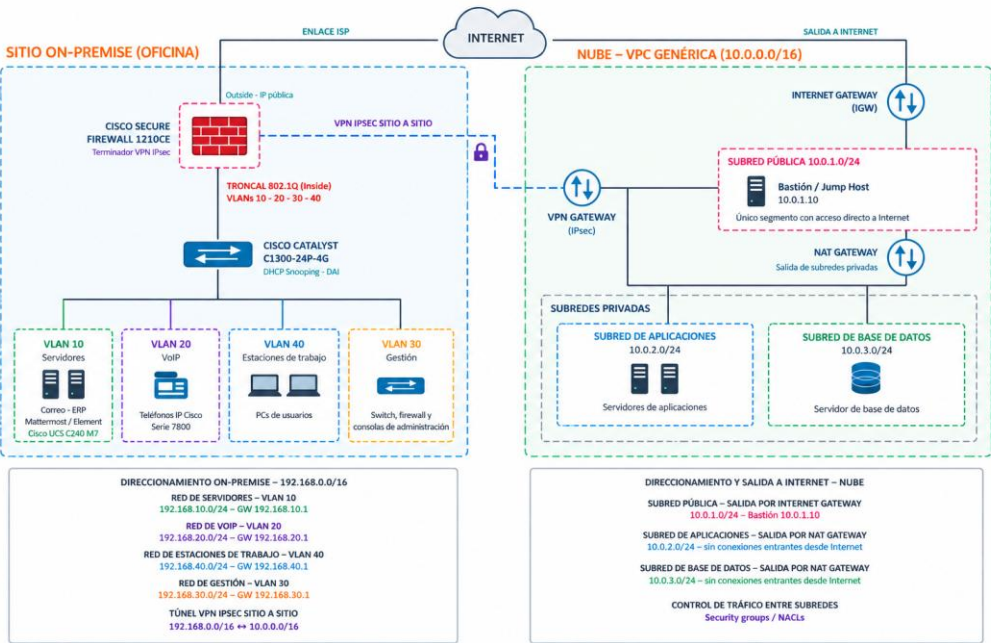
Fundamentos TCP/IP y seguridad por capa. Escenario on-premise Cisco + VPC

1. Arquitectura y supuestos de diseño

La organización opera en una oficina rentada y mantiene servicios tanto en sitio como en una VPC. Para dar un contexto concreto sin sobredimensionar el escenario, la infraestructura local se plantea con Cisco Secure Firewall 1210CE como firewall perimetral y terminador de VPN IPsec, un Cisco Catalyst C1300-24P-4G como switch administrable y un Cisco UCS C220 M7 para alojar las cargas locales. La nube se mantiene genérica, ya que el objetivo es analizar seguridad TCP/IP y no comparar proveedores.

Se conserva el direccionamiento indicado en el planteamiento. Para resolver la ambigüedad entre la red 192.168.20.0/24 y la VLAN 20 de VoIP, se considera 192.168.20.0/24 como segmento de estaciones/servicios de usuario y se mantiene la VLAN 30 de gestión en 192.168.30.0/24. En una implementación real sería preferible separar voz y estaciones en subredes distintas. A continuación, un diagrama esquemático de la solución propuesta.

Ámbito	Segmento	Red	Gateway / función
On-premise	VLAN 10 - servidores/datos	192.168.10.0/24	192.168.10.1
On-premise	VLAN 20 - usuarios/VoIP	192.168.20.0/24	192.168.20.1
On-premise	VLAN 30 - gestión	192.168.30.0/24	192.168.30.1
Nube	Subred pública	10.0.1.0/24	Internet Gateway / NAT Gateway
Nube	Aplicaciones privadas	10.0.2.0/24	Router virtual VPC
Nube	Base de datos privada	10.0.3.0/24	Router virtual VPC



El firewall stateful controla el acceso a Internet y termina la VPN sitio-a-sitio. En la VPC, únicamente la subred pública tiene conectividad directa con Internet; las subredes privadas utilizan el NAT Gateway para iniciar conexiones salientes. La VPN se considera un canal protegido, pero no una extensión automáticamente confiable de la LAN.

2. Análisis de ataques y mitigaciones

Se analizan dos ataques por cada una de tres capas estudiadas: enlace, red y transporte. La probabilidad se valora para este escenario concreto. CIA indica confidencialidad, integridad y disponibilidad.

Capa / ataque	Superficie, impacto y probabilidad	Mitigación propuesta
2. Enlace / ARP spoofing	Un equipo conectado a una VLAN puede anunciar asociaciones IP-MAC falsas y colocarse entre dos hosts. CIA: C alta, I alta, A media. Prob. media: requiere acceso L2, pero la oficina rentada aumenta la exposición física a empleados, visitas o terceros.	En el Catalyst: DHCP Snooping + Dynamic ARP Inspection (DAI); uplinks confiables y puertos de usuario no confiables. DAI valida ARP con la tabla de bindings. Responsable: red LAN. [2]
2. Enlace / VLAN hopping	Una mala configuración de trunks puede permitir acceso a una VLAN no autorizada, especialmente sensible para VLAN 30 de gestión. CIA: C alta, I alta, A media. Prob. baja-media: requiere acceso local y una configuración vulnerable.	Puertos de usuario configurados explícitamente como access; deshabilitar negociación automática de trunks; limitar VLANs permitidas y evitar usuarios en la VLAN nativa. Responsable: switching.
3. Red / IP spoofing	Un atacante genera paquetes con dirección IP origen falsa para intentar evadir controles simples o participar en ataques de reflexión. CIA: C baja, I media, A alta. Prob. media: existen interfaces hacia Internet e interconexión entre dominios.	En Secure Firewall y gateways: filtrado ingress/egress, reglas anti-spoofing y aceptación de prefijos esperados por interfaz. No confiar sólo en la dirección IP como identidad. Responsable: firewall/red.
3. Red / Reconocimiento-abuso de ICMP	ICMP puede apoyar descubrimiento de hosts y generar tráfico contra infraestructura expuesta. CIA: C baja, I baja, A media. Prob. media: las interfaces públicas pueden recibir sondeos de forma frecuente.	Permitir únicamente ICMP necesario y aplicar rate limiting cuando corresponda. No bloquearlo indiscriminadamente, pues cumple funciones operativas de IP. Responsable: firewall/cloud. [5]
4. Transporte / TCP SYN flood	Muchas solicitudes SYN sin completar el three-way handshake consumen recursos de conexiones pendientes. Objetivos principales: servicios publicados y firewall. CIA: C baja, I baja, A alta. Prob. media-alta para servicios públicos y baja para la DB privada.	Limitar conexiones, usar SYN cookies/proxy si la plataforma lo soporta, reducir servicios publicados y complementar en nube con protección DDoS. Responsable: firewall, servidores y nube. [6]
4. Transporte / Session hijacking-TCP RST	Un atacante con visibilidad de una sesión puede intentar interferir o finalizarla mediante segmentos falsificados. CIA: C media, I alta, A media. Prob. baja-media: aumenta si antes se logra una posición MITM dentro de la LAN.	Usar protocolos autenticados y cifrados como TLS/SSH, junto con DAI y segmentación para reducir MITM. TCP por sí mismo no aporta confidencialidad. Responsable: aplicaciones y red.

En la interconexión se propone IPsec en modo túnel con IKEv2. IPsec puede proporcionar confidencialidad, integridad, autenticación y protección contra replay a nivel IP [3]. Aun así, deben existir reglas de mínimo privilegio entre prefijos: por ejemplo, usuarios de 192.168.20.0/24 no deberían acceder directamente a 10.0.3.0/24; las aplicaciones de 10.0.2.0/24 sólo deberían alcanzar los puertos necesarios de base de datos.

3. Riesgos residuales

Ámbito	Riesgo que permanece	Acción recomendada
On-premise	Endpoint autorizado comprometido. Un equipo legítimo puede generar tráfico con direcciones y credenciales válidas; DAI y VLANs no eliminan este escenario.	EDR, parches, MFA, 802.1X/NAC, monitoreo y deshabilitar puertos físicos no utilizados.
Nube	Credenciales o configuración. Un administrador puede exponer accidentalmente un recurso o un atacante puede usar credenciales válidas.	Mínimo privilegio en IAM, MFA, registro de cambios y revisión periódica de reglas de acceso.
Interconexión	Movimiento lateral por la VPN. Comprometer un entorno puede dar una ruta para intentar alcanzar recursos del otro.	ACL/firewall entre prefijos, segmentación, IDS/IPS y registro del tráfico. Tratar la VPN como canal seguro, no como red totalmente confiable.

Adicionalmente, la oficina rentada mantiene un riesgo físico: acceso a cableado, racks o puertos puede facilitar ataques que no atraviesen el perímetro. Por ello conviene restringir físicamente los equipos, deshabilitar puertos no utilizados y autenticar el acceso a la red.

4. Cambio con enlace dedicado

Sustituir la VPN sobre Internet por un enlace dedicado reduce la exposición pública de los gateways utilizados para la interconexión y puede mejorar estabilidad, latencia y capacidad predecible. Sin embargo, privado no significa necesariamente cifrado: el tráfico todavía atraviesa infraestructura de un proveedor y permanecen riesgos de errores de configuración, fallas físicas, acceso del carrier o anuncios de rutas incorrectos.

En capa de enlace seguirían siendo necesarios VLANs, protección de puertos y controles contra ARP spoofing; en capa de red continuarían ACL, filtrado de prefijos y firewalling entre nube y oficina. Si la información es sensible, puede mantenerse IPsec sobre el enlace dedicado. El beneficio principal sería menor exposición a Internet y mayor predictibilidad, a cambio de mayor costo y dependencia del proveedor. Por tanto, el enlace dedicado no sustituye por sí mismo al cifrado ni a la segmentación.

5. Conclusiones

La arquitectura ya incorpora segmentación, firewall stateful, separación de subredes cloud y una VPN sitio-a-sitio, pero ninguno de estos elementos elimina por sí solo los ataques de las distintas capas. Los ataques de enlace requieren controles en el Catalyst; los de red, filtrado y segmentación en firewall/gateways; y los de transporte, reducir exposición y proteger los servicios. La idea central es aplicar controles independientes por capa y permitir únicamente las comunicaciones necesarias, sin asumir que una red es confiable sólo por estar dentro de la oficina, la nube o una VPN.

Referencias

- [1] K. Scarfone y P. Hoffman, Guidelines on Firewalls and Firewall Policy, NIST SP 800-41 Rev. 1, 2009.
- [2] Cisco Systems, documentación técnica de Dynamic ARP Inspection (DAI) y DHCP Snooping.
- [3] S. Kent y K. Seo, Security Architecture for the Internet Protocol, RFC 4301, IETF, 2005.
- [4] D. C. Plummer, An Ethernet Address Resolution Protocol, RFC 826, IETF, 1982.
- [5] J. Postel, Internet Control Message Protocol, RFC 792, IETF, 1981.
- [6] W. Eddy, Ed., Transmission Control Protocol (TCP), RFC 9293, IETF, 2022.
- [7] Cisco Systems, Cisco Secure Firewall 1200 Series; Cisco Catalyst 1300 Series; Cisco UCS C220 M7 product documentation.